

Plan para la recuperación en caso de incidentes

Marzo 2025

Elaborado por: Yulybeth Rios

Plan de Respuesta a Incidentes (basado en NIST SP 800-61)

Planificar: Se debe tener un equipo de respuesta a incidente capacitado y que cada integrante cumpla su rol en caso de incidentes, capacitar al personal sobre que debe hacer en caso de incidente, tener políticas y procedimientos claros sobre que es lo que se va a realizar en la respuesta al incidente y tener siempre como prioridad realizar respaldos periódicamente de toda información

En el caso de un ataque similar esto debe estar presente para cuando un empleado vaya a reportar el problema sepa y tenga a donde dirigirse.

Identificar: Se debe implementar herramientas de monitoreo y análisis de registros log para detectar actividades sospechosas. Establecer canales específicos para que los empleados puedan comunicar posibles incidentes y por ende ellos deben tener conocimiento de medidas de seguridad que hacer en caso de un incidente.

Se debe tener copias de seguridad segura ya que se debe tomar medidas para responder al incidente que pueden borrar información importante.

En un caso similar es muy importante las herramientas de monitoreo, ya que se podría detectar con mayor facilidad por ejemplo sin eso estamos a ciegas y es más complicado detectar como pasó como fué el caso que la máquina de este proyecto no tenía los registros. También saber la configuración de puertos y servicios abiertos (mejorarla)

Contención: Aislar sistemas afectados para evitar que el incidente crezca o el atacante ingrese a áreas importantes, cambiar contraseñas de cuentas potencialmente comprometidas.

En un caso similar es muy importante realizar esto para mantener los servicios funcionando evitar que el ataque avance y las contraseñas deben tener una seguridad eficiente para proteger los datos sensibles, implementar el principio de menor privilegio y control de acceso estricto.

Erradicación: Corregir la vulnerabilidad o malware que haya causado el incidente. Actualizar software y aplicar parches de seguridad.

Para un ataque similar puede jugar mucho a favor actualizar y aplicar parches ya que esto corrige vulnerabilidades que incluso también hacen que no funcione el sistema de manera correcta.

Recuperación: Restaurar los sistemas y datos afectados desde las copias de seguridad seguras que se tengan y ver que los sistemas restaurados estén correctos sin errores.

Para un ataque similar en donde los datos pueden estar de muy fácil acceso como medida de recuperación principal es tomar acción inmediata de erradicar todas las vulnerabilidades en las que se deban cifrar los datos para mantenerlos aún más seguros. Con el fin de que no vuelva a pasar.

* Actividades posteriores al incidente: Se debe documentar las acciones tomadas y los resultados y así revisar lo que ocurrió para determinar lecciones aprendidas y mejorar
Se debe actualizar políticas de prevención e implementar medidas preventivas aprendidas de dicho incidente *

Implementación del SGSI (ISO 27001)

Análisis de Riesgos: Se debe hacer realizar análisis exhaustivo de todo el sistema para comprender los riesgos.

Riesgo	Probabilidad	Impacto	Mitigación
Contraseña debil en usuario root en base de datos	Media	Alto	Implementar contraseñas seguras y cambiarlas regularmente
Servidor ftp permite acceso anónimo	Alta	Medio	Configurar correctamente el servidor
Se permite por SSH ingresar a root	Media	Alto	Se deshabilitó esa función

Definición de Políticas de Seguridad:

- Actualizar software y todo el sistema de manera automática e implementar revisión cada 3 semanas para revisar que se estén aplicando correctamente esas actualizaciones.
- Cambiar contraseñas de todos los usuarios cada 3 meses y evaluar controles de acceso para ellos.

Planes de Acción:

- Tener equipos encargados de que se cumplan todas las medidas de seguridad
- Implementar un sistema de auditoria mensual para evaluar la efectividad de las políticas de seguridad.

Mejora Continua:

- Establecer un proceso de mejora continua para el SGSI, que incluya la revisión periódica de las políticas y procedimientos de seguridad y pruebas de penetración de forma regular.
- Documentar todo el proceso de medidas de protección, planes de acción.